Regulated Google Workspace — Assured Controls, ITAR & DFARS Compliance

Implementation Solution Guide

Version 1.0.0 · 2026-07-06

Contents

Executive Summary — Regulated Google Workspace: Assured Controls, ITAR & DFARS 4

The problem . . . 4

The solution . . . 4

What is explicitly out of scope . . . 4

Business outcome . . . 4

Effort & risk . . . 5

1. Solution Overview — Regulated Google Workspace: Assured Controls, ITAR & DFARS 5

What this solution does . . . 5

The Google capabilities this solution configures . . . 5

How the controls map to controlled-data requirements . . . 6

What this solution does *not* do . . . 7

Benefits . . . 7

Limitations (be honest with buyers) . . . 7

The deployment model . . . 7

2. Requirements Guide — Regulated Google Workspace: Assured Controls, ITAR & DFARS 8

2.1 Assured Controls / Assured Controls Plus add-on on a qualifying edition . . . 8

2.2 Compliance / legal / export-control stakeholders and requirements (the interpretation owners) . 9

2.3 Data classification / controlled-data scope . . . 9

2.4 Data-regions capability for residency . . . 9

2.5 Client-Side Encryption (CSE) readiness — only if relied upon (legal-gated) . . . 9

2.6 Super-admin / scoped admin access for the compliance surfaces . . . 9

2.7 Pilot scope (controlled-data OU or group) and change control . . . 10

2.8 Evidence / audit destination . . . 10

Checklist . . . 10

Global Requirements — Google Workspace & Gemini Solutions 11

1. Google Workspace / Cloud Identity tenant . . . 11

2. Source Microsoft 365 / Entra environment (for migration & coexistence) . . . 11

3. DNS control for the routed domains . . . 12

4. Identity & provisioning source of truth . . . 12

5. A pilot scope (OU / group) and change control . . . 12

6. Security, compliance & governance stakeholders . . . 12

3. Implementation Guide — Regulated Google Workspace: Assured Controls, ITAR & DFARS 13

Step 0 — Assess: baseline the current controlled-data posture . . . 13

Step 1 — Configure data-region residency (data at rest) for the pilot scope . . . 13

Step 2 — Configure Access Management (limit Google support staff) for the pilot scope . . . 14

Step 3 — Enable Access Approvals for the pilot scope . . . 14
Step 4 — Stand up the evidence surface (Access Transparency + reporting) . . . 15
Step 5 — (If legal requires) configure Client-Side Encryption for controlled services . . . 15
Step 6 — Pilot & Validate against the compliance requirements . . . 16
Step 7 — Remediate gaps (safe, -WhatIf by default) . . . 16
Step 8 — Expand to the full controlled-data population . . . 16
Deployment summary . . . 17
5. Testing & Validation — Regulated Google Workspace: Assured Controls, ITAR & DFARS 17
Test 1 — Data-region residency . . . 18
Test 2 — Access Management policy . . . 18
Test 3 — Access Approvals . . . 18
Test 4 — Access Transparency evidence . . . 18
Test 5 — Client-Side Encryption (only if relied upon) . . . 19
Test 6 — Compliance-evidence exports . . . 19
Test 7 — Functional / no-regression on the pilot . . . 19
Test 8 — Coverage & sign-off gate (pilot exit) . . . 19
Pass/fail summary . . . 20
6. Troubleshooting — Regulated Google Workspace: Assured Controls, ITAR & DFARS 20
Access Management / Access Approvals . . . 20
Data regions / residency . . . 21
Client-Side Encryption (CSE) . . . 21
Evidence / Access Transparency . . . 22
Scripts . . . 22
7. Best Practices — Regulated Google Workspace: Assured Controls, ITAR & DFARS (Evidence & Audit) 23
Governance & interpretation . . . 23
Scope & configuration discipline . . . 23
Evidence & audit . . . 23
Operational safety . . . 24
Anti-patterns to avoid . . . 24
8. Deliverables Summary — Regulated Google Workspace: Assured Controls, ITAR & DFARS 24
Documentation . . . 25
Scripts (5) . . . 25
How they fit the deployment model . . . 26
Outcome . . . 26
Appendix A — PowerShell Scripts 27

Executive Summary — Regulated Google Workspace: Assured Controls, ITAR & DFARS

The problem

Enterprises with **ITAR** or **DFARS** obligations cannot simply turn on Google Workspace for controlled data. Controlled Unclassified Information and export-controlled technical data need three boundaries the default tenant does not provide: **where data lives** (residency/sovereignty), **who can touch it in support** (provider-access limits), and **a policy configuration** aligned to the applicable regime and to internal compliance policy. Turned on without these, Workspace leaves controlled data with no sovereignty guarantee, open provider-support access, and no evidence to show an auditor.

The solution

Configure Google Workspace for controlled data using **Assured Controls** (a paid add-on on Frontline Plus / Enterprise Plus) and the related **data-region**, **access-management**, and **access-approval** capabilities:

- **Data-region residency** — pin data at rest to the required region (typically the **United States**).
- **Access Management** — limit which Google support staff can act on the data (**U.S.-persons-only**, or **CJIS / IRS 1075-authorized** staff), addressing the foreign-person-access concern.
- **Access Approvals + Access Transparency** — require approval before any provider access, with a logged, auditable trail.
- **Client-Side Encryption** — where legal relies on the ITAR end-to-end-encryption carve-out.
- **Compliance evidence** — policy-compliance log events, data-regions reporting, and compliance exports as audit proof.

Everything is deployed **pilot-first** on a curated OU, **validated against the required posture**, and **expanded** only after legal/compliance sign-off — with named, reusable configurations and a documented rollback.

What is explicitly out of scope

Regulatory interpretation is deferred to legal/compliance. This solution delivers the **technical configuration and the evidence** — it does **not** make legal determinations about whether a configuration satisfies ITAR, DFARS/NIST 800-171, or any regime for your data. It never invents Assured Controls specifics; edition-/contract-dependent details are cited or flagged **"verify in your tenant."**

Business outcome

Controlled data in Google Workspace with **sovereignty, provider-access boundaries, and an audit-ready evidence trail** — aligned to ITAR/DFARS and internal policy, proven on a pilot before you scale. Self-guided and tested, at a fraction of the cost of a bespoke compliance engagement — with the legal determination left, correctly, to your compliance team.

Effort & risk

• **Effort tier:** T4 — architecture/governance work on a live, regulated environment.

• **Risk posture:** read-only discovery/validation/reporting; state-changing steps default to `-WhatIf`; pilot gate and rollback on every production change.

• **Prerequisites:** Assured Controls add-on on a qualifying edition; named legal/compliance owners; data classification; super-admin/scoped compliance roles; a pilot OU.

1. Solution Overview — Regulated Google Workspace: Assured Controls, ITAR & DFARS

What this solution does

Enterprises with **ITAR** (International Traffic in Arms Regulations) or **DFARS** (Defense Federal Acquisition Regulation Supplement) obligations cannot simply turn on Google Workspace for controlled data. Controlled Unclassified Information (CUI), export-controlled technical data, and similar regulated content need three technical boundaries in place: **where the data lives** (sovereignty / residency), **who can touch it in support** (provider-access controls), and **a policy configuration** that aligns Workspace to the applicable regime and to internal compliance policy. This solution configures those boundaries in Google Workspace using **Assured Controls** and the related **data-region**, **access-management**, and **access-approval** capabilities — deployed **pilot-first** and **rollback-ready**.

> ***Regulatory interpretation is deferred to legal / compliance.*** *This solution provides the **technical configuration and the evidence** — it does **not** make legal determinations about whether a given configuration satisfies ITAR, DFARS/NIST 800-171, or any other regime for your data. Which controlled-data categories apply, whether a specific control set is sufficient, and how encryption carve-outs are interpreted are decisions for your **legal / export-compliance and security** stakeholders. The technical steps below cite Google's public documentation; anything not confirmable from that documentation (or that depends on your contract/edition) is flagged **"verify in your tenant."***

The Google capabilities this solution configures

Assured Controls is a **paid add-on** for Google Workspace, offered as **Assured Controls** and **Assured Controls Plus**, available with **Frontline Plus or Enterprise Plus** editions ([Google — About Assured Controls][ac]). The capabilities that matter for controlled data are:

• **Access Management** — geographically and eligibility-limits the **Google support staff** who can take support actions on your data. Policy options published by Google: **No preference**; **U.S. Google staff only** (U.S. persons in a physical U.S. location); **CJIS / IRS 1075-authorized staff only** (U.S. persons in a U.S. location who have completed appropriate background checks); and an **EU staff** option ([Google — Access Management][am]). This is the control most directly relevant to export-controlled data's "no unauthorized foreign-person access" concern — **subject to your legal team's interpretation.**

• **Access Approvals** — requires Google staff to **request and receive approval** before viewing data

in the course of support. Approvals are surfaced in **Access Transparency** logs ([Google — Access Approvals][aa]).

• **Access Transparency** — near-real-time **logs of Google-staff access** to your content, the

audit/evidence surface behind Access Management and Access Approvals ([Google — Access Transparency logs][at]).

• **Data regions** — pins **data at rest** to a chosen geography (**No Preference / United States /

Europe**), configurable per** OU or configuration group **via** Data regions → Advanced settings **([Google — Data regions advanced settings][dr]). For ITAR/DFARS,** United States **residency is the typical target —** confirm scope with legal.**

• **Client-Side Encryption (CSE)** — encrypts content with keys you control, so it is indecipherable to

Google. Google's public ITAR guidance positions **Workspace CSE** as usable, when properly configured, to meet the ITAR **end-to-end-encryption carve-out** for export-controlled technical data ([Google Cloud — ITAR][itar]). **This carve-out is a legal interpretation — do not treat CSE configuration alone as ITAR compliance; confirm with export-compliance counsel.**

• **Compliance supporting features bundled with the add-on** — **compliance data exports**,

data-regions advanced reporting, **local data storage**, **policy-compliance log events**, and **Google Meet compliance recording** ([Google — About Assured Controls][ac]). These are the **evidence and reporting** surfaces this solution uses to demonstrate coverage.

How the controls map to controlled-data requirements

Controlled-data need	Google capability this solution configures	Evidence surface
Data residency / sovereignty (keep data at rest in-region, e.g. U.S.)	**Data regions** (Data at rest = United States), per OU/group	Data-regions advanced reporting
Limit provider (Google support) access by nationality / location / clearance	**Access Management** (U.S.-only / CJIS-IRS-1075)	Access Transparency logs
Require approval before any provider access	**Access Approvals**	Access Transparency logs
Provider-access visibility / audit	**Access Transparency**	Access Transparency log events
Keep content indecipherable to the provider (ITAR e2ee carve-out — *legal-gated*)	**Client-Side Encryption (CSE)**	CSE / policy-compliance logs
Demonstrable, exportable compliance evidence	**Compliance data exports, policy-compliance log events**	Reports / exports

> *The mapping shows **which technical control addresses which requirement**. Whether the combination is **sufficient** for your ITAR/DFARS obligations is a **legal/compliance determination**, not a technical one.*

What this solution does *not* do

• It does **not** provide legal or export-compliance advice, nor certify ITAR/DFARS/NIST 800-171 compliance. It provides the configuration and the evidence for your compliance team to assess.

• It does **not** invent Assured Controls specifics. Where Google's public documentation does not state a detail, or where a feature is edition-/contract-dependent, the step is **cited or flagged "verify in your tenant"** rather than asserted.

• It does **not** replace **Google Cloud Assured Workloads** (the Cloud/ITAR data-boundary product for Google Cloud Platform resources). This solution is about **Google Workspace** controlled-data configuration; the GCP-side ITAR data boundary is referenced but its console steps are deferred to Google Cloud documentation.

Benefits

• **Sovereignty** — controlled data at rest pinned to the required region (typically U.S.).

• **Provider-access boundaries** — Google support access limited by location / eligibility and gated by approval, with a transparent access log for evidence.

• **Compliance-aligned policy set** — a named, reusable configuration mapped to controlled-data requirements, applied by OU/group.

• **Evidence-first** — Access Transparency logs, compliance data exports, and policy-compliance log events give auditors demonstrable coverage.

• **Controlled blast radius** — a pilot OU/group proves the configuration before fleet-wide rollout, with a documented rollback.

Limitations (be honest with buyers)

• **Legal interpretation is out of scope** — technical configuration and evidence only; compliance determinations belong to legal/compliance.

• Assured Controls / Access Management **feature availability and policy options are edition- and contract-dependent **and evolve; every add-on-gated step is flagged** "verify in your tenant."**

• Access Management policies apply **only to users in OUs that hold Assured Controls licenses** ([Google — Access Management][am]) — licensing scope is a prerequisite, not an afterthought.

• CSE's ITAR carve-out is a **legal position**, not a checkbox; correct CSE key management and scope are required and still require counsel's sign-off.

The deployment model

> ***Assess controlled-data posture** → **Configure residency, access-management/approval, and the policy set** → **Pilot on a curated OU/group** → **Validate against the compliance requirements** → **Expand**, with explicit pass/fail gates and a documented rollback for every production change. This is the standard **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** model for the Google category.*

[ac]: https://support.google.com/a/answer/13880647 "About Assured Controls and Assured Controls Plus — Google Workspace Admin Help" [am]: https://support.google.com/a/answer/10343878 "Access Management: Limit the Google staff who can take support actions related to your data — Google Workspace Admin Help" [aa]: https://support.google.com/a/answer/12410469 "Access Approvals — Google Workspace Admin Help" [at]: https://support.google.com/a/answer/9230474 "Access Transparency: View logs on Google access to user content — Google Workspace Admin Help" [dr]: https://knowledge.workspace.google.com/admin/compliance/set-up-advanced-settings-for-data-regions "Set up advanced settings for data regions — Google Workspace Admin Help" [itar]: https://cloud.google.com/security/compliance/itar "International Traffic in Arms Regulations (ITAR) — Google Cloud"

2. Requirements Guide — Regulated Google Workspace: Assured Controls, ITAR & DFARS

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites are in `global-requirements-google.md`.

> ***Vendor boundary.** Google Workspace Admin console paths are authored from Google's current public documentation. **Assured Controls / Access Management policy options and edition gating are contract-/edition-dependent and evolve** — confirm exactly what applies to *your* licensing. Anything not confirmable from public documentation is flagged **"verify in your tenant."***

> ***Regulatory interpretation is deferred to legal / compliance.** The requirements below are **technical prerequisites**. Which controlled-data categories apply and whether a control set is sufficient are **legal/compliance determinations** — see requirement 2.2.*

2.1 Assured Controls / Assured Controls Plus add-on on a qualifying edition

Description: The **Google Workspace Assured Controls** (or **Assured Controls Plus**) paid add-on, on **Frontline Plus or Enterprise Plus**, licensed for the users/OUs in scope for controlled data. **Why:** Access Management, Access Approvals, and the bundled compliance/reporting features require the add-on; policies apply **only to users in OUs that hold the license**. **Access Management** in particular requires **Assured Controls Plus** (or legacy Assured Controls purchased before the cutover Google documents) — *verify which SKU carries each feature for your contract.* **Verify:** Admin console (`https://admin.google.com`) → **Billing** → **Subscriptions**; confirm the Assured Controls / Assured Controls Plus add-on and the base edition (Frontline Plus / Enterprise Plus) and license counts. *(Verify in your tenant — SKU-to-feature mapping evolves.)* **Implement: Contact Google Workspace sales** or an authorized reseller to acquire the add-on and qualifying base edition for the controlled-data population; do **not** assume it is bundled.

2.2 Compliance / legal / export-control stakeholders and requirements (the interpretation owners)

Description: Engagement with **legal / export-compliance**, **security (CISO)**, and **data-governance** owners who define which regime(s) apply (ITAR, DFARS/NIST 800-171, CJIS, IRS 1075, internal policy), which data is in scope, and which Access-Management / residency posture is **required** — and who **sign off** that the technical configuration is sufficient. **Why:** This solution provides configuration and evidence, **not** legal determinations. The required data region, the required Access-Management policy (e.g. U.S.-only vs CJIS/IRS-1075), and whether CSE's ITAR carve-out is being relied upon are **their** decisions, not technical defaults. **Verify:** Named owners exist; the applicable regime(s), in-scope data categories, and the required control posture are documented and approved. **Implement:** Identify the owners and obtain the written control requirements **before** configuring; record who approves the pilot exit and the fleet expansion (global requirement 6).

2.3 Data classification / controlled-data scope

Description: A defined mapping of **which users, OUs, and data** are controlled (CUI / export-controlled / regulated) versus general, so residency and access controls target the right scope. **Why:** Applying U.S.-residency and U.S.-only-support policies to *everyone* is unnecessary and disruptive; applying them too narrowly leaves controlled data exposed. The scope decision drives the OU design. **Verify:** A data-classification/scope document exists and maps to OUs/groups; run `GWREG-Discovery.ps1` to see current residency/CSE/OU posture as a baseline. **Implement:** Work with the stakeholders in 2.2 to classify data and map it to a controlled-data OU structure; stage the OU targeting with `GWREG-Set-ScopeTargeting.ps1` before applying controls.

2.4 Data-regions capability for residency

Description: The **Data regions** capability (fundamental data regions, plus **Advanced settings** for per-OU/group control), available with **Frontline Plus, Enterprise Plus, or the Data Regions add-on**. **Why:** Residency (data at rest = **United States** for ITAR/DFARS, typically) is configured here; Advanced settings let you control cross-region processing per OU/group. **Verify:** Admin console → **Data** → **Compliance** → **Data regions**; confirm the page is present and **Advanced settings** is available. *(Advanced settings require the qualifying edition/add-on — verify in your tenant.)* **Implement:** Ensure the qualifying edition/add-on is licensed; assign the operator the compliance/data admin privileges to edit data regions.

2.5 Client-Side Encryption (CSE) readiness — only if relied upon (legal-gated)

Description: If your compliance team relies on the **ITAR end-to-end-encryption carve-out**, a configured **CSE** setup: an external key service / IdP for CSE, enabled per-service, scoped to the controlled OUs. **Why:** Google positions Workspace CSE, properly configured, as usable to meet the ITAR e2ee carve-out ([Google Cloud — ITAR][itar]) — but this is a **legal interpretation**. CSE also affects functionality (some features cannot read CSE content), so scope must be deliberate. **Verify:** Admin console → **Data** → **Compliance** → **Client-side encryption**; confirm the key service/IdP and which services are CSE-enabled. *(Whether CSE is required is a legal decision — 2.2.)* **Implement:** Only if legal requires it: stand up the CSE key service/IdP per Google's CSE documentation, then enable CSE for the controlled OUs. Defer key-service internals to the vendor's docs.

2.6 Super-admin / scoped admin access for the compliance surfaces

Description: The operator holds the roles to configure **Access Management, Access Approvals, Data regions, and CSE** — these live under **Data** → **Compliance** and require **super administrator** access for Access Management ([Google — Access Management][am]). **Why:** These compliance controls are high-impact and gated to super-admin (Access Management) or scoped compliance-admin roles. **Verify:** Admin console → **Account** → **Admin roles**; confirm super-admin (for Access Management) and compliance/data privileges (Data regions, Access Approvals, CSE). **Implement:** Assign the least-privilege roles for each surface; reserve super-admin for the Access-Management change and record who holds it.

2.7 Pilot scope (controlled-data OU or group) and change control

Description: A **pilot OU or group** of representative controlled-data users (e.g. `Regulated Workspace – Controlled Data – Pilot`) and a documented **change/rollback** process for residency, access, and CSE changes. **Why:** Every control is validated on a small, curated scope before fleet expansion; residency and CSE changes are high-impact and must be reversible under change control (global requirement 5). **Verify:** Admin console → **Directory** → **Organizational units** (or **Groups**); the pilot scope exists. Or run `GWREG-Set-ScopeTargeting.ps1`. **Implement:** Create the pilot OU/group (with `GWREG-Set-ScopeTargeting.ps1` or Admin console → **Directory**), add a few representative controlled-data users, and agree the change window/rollback with the owners in 2.2.

2.8 Evidence / audit destination

Description: A defined destination and cadence for the **evidence** this solution produces — Access Transparency logs, compliance data exports, and policy-compliance log events — to satisfy auditors. **Why:** Controlled-data programs must **demonstrate** coverage, not just configure it; the evidence must be collected and retained. **Verify:** Confirm where Access Transparency / policy-compliance log events are reviewed (Admin console reporting, or exported to your SIEM/evidence store) and the retention requirement. **Implement:** Define the export/retention path; `GWREG-Report.ps1` compiles a coverage/evidence report you can attach to the audit record.

Checklist

- Assured Controls / Assured Controls Plus add-on on Frontline Plus / Enterprise Plus licensed for the controlled scope (verify SKU-to-feature)
- Legal/export-compliance + security stakeholders named; applicable regime, in-scope data, and required posture documented **and approved**
- Data classification / controlled-data scope mapped to OUs — baseline via `GWREG-Discovery.ps1`
- Data regions capability (Advanced settings) available for residency
- CSE readiness confirmed **only if** legal relies on the ITAR e2ee carve-out
- Admin roles assigned (super-admin for Access Management; compliance/data for Data regions, Access Approvals, CSE)
- `Regulated Workspace – Controlled Data – Pilot` scope created; change control / rollback documented
- Evidence/audit destination and retention defined

[am]: https://support.google.com/a/answer/10343878 "Access Management — Google Workspace Admin Help" [itar]: https://cloud.google.com/security/compliance/itar "International Traffic in Arms Regulations (ITAR) — Google Cloud"

Global Requirements — Google Workspace & Gemini Solutions

These requirements apply to **every** solution in the **Google** category. They are the common foundation each Google Workspace / Gemini solution assumes is already in place (or stands up as part of its own Requirements section). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Google solution).*** *The **Google Admin console** (admin.google.com), **Google Cloud / Cloud Identity**, and the **Microsoft / Entra** sides are authored at exact, current click-by-click detail from the vendors' public documentation. **Gemini Enterprise** capabilities that are in preview or rolling out are **cited or flagged "verify in your tenant"** — never invented. **Third-party migration tools** (e.g. for mail/Drive/Chat data movement) and **third-party enterprise apps** (ServiceNow, SAP, Databricks, etc.) are integrated at the pattern/architectural level; their internal console steps are deferred to the vendor's own docs.*

1. Google Workspace / Cloud Identity tenant

• **Description:** A provisioned Google Workspace (or Cloud Identity) tenant with a **super-admin** account for configuration, and the appropriate Workspace edition/licensing for the capability in scope (e.g. Enterprise Plus for Vault/CAA/DLP, Gemini/AI add-on where required).

• **Why required:** All configuration, policy, and API work is performed against this tenant.

• **How to verify:** Sign in to **admin.google.com** as a super-admin; confirm edition and license counts under **Billing / Subscriptions**.

• **How to implement if missing:** Provision the tenant and licenses through Google or an authorized reseller before starting.

2. Source Microsoft 365 / Entra environment (for migration & coexistence)

• **Description:** For migration/coexistence/identity solutions, administrative access to the source **Microsoft 365** tenant and **Microsoft Entra ID** (Global Administrator or the least-privilege roles the solution names).

• **Why required:** Migration, directory sync, SSO federation, and coexistence read from and change the Microsoft side.

• **How to verify:** Confirm access to the M365 admin center and the Entra admin center with the required role.

• **How to implement if missing:** Obtain the role from the M365/Entra tenant owner.

3. DNS control for the routed domains

• **Description:** Ability to create/modify **DNS records** (MX, SPF, DKIM, DMARC, TXT, CNAME) for the domains being migrated, coexisting, or verified.

• **Why required:** Domain verification, mail routing/coexistence, and authentication all depend on DNS changes.

• **How to verify:** Confirm access to the authoritative DNS zone for each domain.

• **How to implement if missing:** Coordinate with whoever controls DNS; stage changes under change control (mail-flow changes are high-impact).

4. Identity & provisioning source of truth

• **Description:** A defined **identity source of truth** (on-prem AD, Entra ID, or an HR/IGA system) and the sync mechanism (e.g. **Google Cloud Directory Sync (GCDS)** or SCIM-based provisioning).

• **Why required:** Consistent users/groups across ecosystems underpin SSO, licensing, and access.

• **How to verify:** Confirm which directory is authoritative and how objects flow into Google.

• **How to implement if missing:** Define the source of truth and provisioning model before configuring SSO or migrating.

5. A pilot scope (OU / group) and change control

• **Description:** A **pilot organizational unit or group** to validate on before fleet-wide rollout, and a **change-control** process for production changes (especially mail flow, DNS, identity, and DLP).

• **Why required:** Every solution follows an **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** model; the pilot proves the design and change control protects production.

• **How to verify:** Confirm a named pilot OU/group exists and a change window/approval path is available.

• **How to implement if missing:** Create a pilot OU/group and agree the change-control process with the owners before making production changes.

6. Security, compliance & governance stakeholders

• **Description:** Engagement with the **security (CISO), legal/eDiscovery, and data-governance** stakeholders whose policies the configuration must satisfy (DLP, retention, Vault/Purview, and any regulatory regime such as ITAR/DFARS/Assured Controls where applicable).

• **Why required:** Data governance, eDiscovery, DLP, and regulated-workload settings must align to enterprise policy and legal requirements, not just technical defaults.

• **How to verify:** Confirm the applicable policies and named stakeholders/approvers.

• **How to implement if missing:** Identify the owners and obtain the policy/compliance requirements before configuring governance controls.

*The deployment model across every Google solution is the same: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand**, with explicit pass/fail gates and a documented rollback for production changes.*

3. Implementation Guide — Regulated Google Workspace: Assured Controls, ITAR & DFARS

Configure controlled-data boundaries in Google Workspace: **data-region residency**, **access-management / access-approval** controls, and a **named policy set for controlled data** — validated against the compliance requirements on a **pilot**, then expanded. Follow the **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** model with a gate at each step and a documented rollback.

> ***Full Admin console navigation is given click-by-click*** *from Google's public documentation. Menu paths reflect the current* ***Data*** *→* ***Compliance*** *location for these controls.* ***Add-on-gated features and policy options are edition-/contract-dependent*** *and are flagged* ***"verify in your tenant."*** ***Regulatory interpretation is deferred to legal/compliance*** *— every "which policy / which region" choice is theirs (requirement 2.2), not a technical default.*
>
> ***Sign in*** *to the Google Admin console at* `https://admin.google.com` *with a* ***super administrator*** *account (required for Access Management). The controlled-data compliance controls live under* ***Menu*** *→* ***Data*** *→* ***Compliance****.*

Step 0 — Assess: baseline the current controlled-data posture

Goal: know the starting state before changing anything.

1. Run `GWREG-Discovery.ps1` (read-only) to enumerate, for the tenant/OUs in scope: current **data region **posture,** CSE **enablement per service,** Access Management / Access Approvals **state (as readable), and the controlled-data** OU** layout.

1. Confirm licensing: Admin console → **Billing** → **Subscriptions** — Assured Controls / Assured Controls

Plus add-on present on Frontline Plus / Enterprise Plus (requirement 2.1).

1. With the stakeholders (requirement 2.2), confirm the **required** posture: target **data region** (typically **United States**), required **Access Management policy** (e.g. **U.S. staff only** or **CJIS / IRS 1075-authorized only**), whether **Access Approvals** is required, and whether **CSE** is relied upon.

1. **Gate:** licensing confirmed, required posture documented and **approved** by legal/compliance, pilot OU (`Regulated Workspace – Controlled Data – Pilot`) exists (requirement 2.7). Do not proceed without the approved target posture.

Step 1 — Configure data-region residency (data at rest) for the pilot scope

Goal: pin controlled data at rest to the required region.

1. Go to **Menu** → **Data** → **Compliance** → **Data regions**.

2. Select the **pilot OU** (`Regulated Workspace – Controlled Data – Pilot`) — not the top OU yet.

3. Set **Data at rest** to the required region: **United States** (for ITAR/DFARS, per legal —

requirement 2.2). Options are **No Preference / United States / Europe**.

1. **Save** (choose **Override** if prompted for a child OU).

2. **Advanced settings (cross-region processing):** go to **Data regions** → **Advanced settings**. Per

service (**Gmail, Drive/Docs, Calendar, Chat, Meet**) choose **Enable** or **Disable** features that may process data across multiple regions. **Disable** where legal requires strict in-region processing — note Google's caution that disabling may remove familiar functionality. **Save / Override.** *(Advanced settings require the qualifying edition/add-on — verify in your tenant.)*

1. Name this configuration in your runbook as `RES-US-Controlled` so it is reused verbatim when you

expand.

> ***Residency is not instantaneous.*** *Data at rest moves to the region on Google's schedule; verify in the data-regions reporting (Step 4) rather than assuming immediate effect.*

Step 2 — Configure Access Management (limit Google support staff) for the pilot scope

Goal: limit which Google staff can take support actions on controlled data.

1. Go to **Menu** → **Data** → **Compliance** → **Access Management** (super-admin required).

2. Select the **pilot OU** (or the controlled-data group).

3. Choose the **policy required by legal/compliance** (requirement 2.2), from Google's published options:

• **No preference** — does not limit support personnel (not for controlled data).

• **U.S. staff only** — U.S. persons in a physical U.S. location.

• **CJIS / IRS 1075-authorized only** — U.S. persons in a U.S. location who have completed

appropriate background checks.

• **EU staff** — EU staff in EU locations (where an EU posture is required instead).

1. **Save** (or **Override** for a child OU).

2. Name it `AXM-US-Controlled` (or `AXM-CJIS-Controlled`) and reuse verbatim on expansion.

> ***Licensing scope matters:*** *Access Management policies apply* ***only to users in OUs that hold the Assured Controls license*** *([Google — Access Management][am]). Confirm the pilot OU is licensed.*

Step 3 — Enable Access Approvals for the pilot scope

Goal: require Google staff to get approval before viewing data for support.

1. Go to **Menu** → **Data** → **Compliance** → **Access Approvals**.
2. Select the **pilot OU** (or leave top OU only when expanding tenant-wide).
3. Check **"Require Google staff to request approval before viewing data necessary for support services."**
1. **Save.** Approval events are surfaced in **Access Transparency** logs (Step 4).
2. Define **who approves** requests and the SLA in your runbook (an internal process, not a Google setting).

Step 4 — Stand up the evidence surface (Access Transparency + reporting)

Goal: make provider-access visible and auditable.

1. Confirm **Access Transparency** logging: Admin console reporting → choose **Access Transparency log events** from the data-source list ([Google — Access Transparency logs][at]). These log Google-staff access allowed via Access Management / Access Approvals.
1. Enable the bundled evidence features included with the add-on where required: **policy-compliance log events**, **data-regions advanced reporting**, and **compliance data exports** ([Google — About Assured Controls][ac]).
1. Point the evidence at your retention/SIEM destination (requirement 2.8).
2. Run `GWREG-Report.ps1` to compile a **coverage/evidence** report (residency, Access Management/ Approvals state, CSE, and Access-Transparency availability) for the pilot scope.

Step 5 — (If legal requires) configure Client-Side Encryption for controlled services

Goal: make controlled content indecipherable to Google, if the ITAR e2ee carve-out is relied upon.

> ***Only perform this step if legal/compliance requires CSE*** *(requirement 2.2 / 2.5). CSE is a legal position, not a default.*

1. Go to **Menu** → **Data** → **Compliance** → **Client-side encryption**; confirm the external **key service / IdP** is connected (stand up per Google's CSE documentation — deferred to vendor docs).
1. Enable CSE for the required services (e.g. **Drive/Docs, Gmail, Meet, Calendar**) scoped to the **pilot controlled-data OU**.
1. Record the scope and key-management ownership in the runbook; note CSE functional tradeoffs for users.

Step 6 — Pilot & Validate against the compliance requirements

Goal: prove the configuration satisfies the *required* posture on the pilot before expanding.

1. Run `GWREG-Validation.ps1` against the pilot OU — it checks each configured control **against the

required posture **you recorded in Step 0 (residency = target region, Access Management = required policy, Access Approvals on, CSE where required) and reports** pass/fail per control per scope**.

1. Run `GWREG-Report.ps1` to produce the coverage/evidence report for the pilot.

2. Test functionally: confirm pilot users can work; confirm data-regions reporting shows in-region

residency; generate a support interaction (if feasible) and confirm it appears in **Access Transparency** and was gated by **Access Approvals**.

1. **Have legal/compliance review the validation output and evidence** and sign off that the pilot

posture meets the requirement. *(This is their determination — not a script pass.)*

1. **Gate:** all required controls **pass** for the pilot **and** legal/compliance has signed off.

Otherwise remediate (Step 7) and re-validate.

Rollback (if the pilot fails): revert data region to **No Preference**, set Access Management back to the prior policy, uncheck Access Approvals, and (if enabled) disable CSE for the OU — all per the change ticket, then re-baseline with `GWREG-Discovery.ps1`.

Step 7 — Remediate gaps (safe, -WhatIf by default)

Goal: close any control that failed validation.

1. Run `GWREG-Remediation.ps1` — it **defaults to** `-WhatIf` and only **previews** the changes needed

to bring a scope to the required posture (e.g. set data region, set Access-Management policy, enable Access Approvals).

1. Review the preview with the change approver.

2. Re-run with `-Execute` (or `-WhatIf:$false`) **only** inside the approved change window, then

re-validate (Step 6).

Step 8 — Expand to the full controlled-data population

Goal: roll the proven, named configuration to all controlled-data OUs.

1. Apply the **same named configurations** — `RES-US-Controlled`, `AXM-US-Controlled` (or

`AXM-CJIS-Controlled`), Access Approvals, and CSE where required — to the remaining controlled-data OUs/groups (use `GWREG-Set-ScopeTargeting.ps1` to grow the scope consistently).

1. Confirm each expanded OU is **Assured Controls-licensed** before applying Access Management.

2. Run `GWREG-Validation.ps1` and `GWREG-Report.ps1` across the expanded scope; attach the evidence to

the audit record.

1. **Gate:** full controlled scope passes validation and legal/compliance sign-off is recorded. Leave

general (non-controlled) OUs unchanged.

Deployment summary

Step	Action	Admin path	Evidence
0	Assess baseline & confirm required posture	Billing → Subscriptions; `GWREG-Discovery.ps1`	Baseline report
1	Data-region residency (`RES-US-Controlled`)	Data → Compliance → Data regions (+ Advanced settings)	Data-regions reporting
2	Access Management (`AXM-US-Controlled`)	Data → Compliance → Access Management	Access Transparency
3	Access Approvals	Data → Compliance → Access Approvals	Access Transparency
4	Evidence surface	Reporting → Access Transparency log events; add-on exports	Logs / exports
5	CSE (if legal-required)	Data → Compliance → Client-side encryption	CSE / policy logs
6	Pilot & validate + legal sign-off	`GWREG-Validation.ps1` / `GWREG-Report.ps1`	Pass/fail + evidence
7	Remediate (`-WhatIf` default)	`GWREG-Remediation.ps1`	Change record
8	Expand	`GWREG-Set-ScopeTargeting.ps1` + re-validate	Coverage report

[ac]: https://support.google.com/a/answer/13880647 "About Assured Controls and Assured Controls Plus — Google Workspace Admin Help" [am]: https://support.google.com/a/answer/10343878 "Access Management — Google Workspace Admin Help" [at]: https://support.google.com/a/answer/9230474 "Access Transparency — Google Workspace Admin Help"

5. Testing & Validation — Regulated Google Workspace: Assured Controls, ITAR & DFARS

Test each control **against the required posture** (the target region and policy legal/compliance approved in requirement 2.2 / Implementation Step 0), on the **pilot scope first**, with an explicit **pass/fail** gate before expansion. Testing confirms the **technical configuration and evidence** — it does **not** constitute a legal determination of ITAR/DFARS compliance (that sign-off is legal/compliance's, per Implementation Step

6.4).

> *Run the read-only scripts (`GWREG-Discovery.ps1`, `GWREG-Validation.ps1`, `GWREG-Report.ps1`) to gather evidence; confirm the same state in the Admin console. Where a check depends on add-on/edition, treat a "cannot read" result as **"verify in your tenant,"** not a pass.*

Test 1 — Data-region residency

- **What:** Data at rest for the pilot OU is set to the required region (e.g. **United States**).
- **How:** Admin console → **Data** → **Compliance** → **Data regions** shows the pilot OU on the required region; **Data-regions advanced reporting** confirms in-region residency. `GWREG-Validation.ps1` reports residency = target.
- **Pass:** Region = required target for all pilot users; advanced reporting confirms.
- **Fail:** Region is No Preference/wrong, or reporting shows out-of-region data → remediate (Step 7), allowing for Google's migration schedule.

Test 2 — Access Management policy

- **What:** The required Access-Management policy (**U.S. staff only** or **CJIS / IRS 1075-authorized only**) is applied to the pilot OU, and the OU is Assured Controls-licensed.
- **How:** Admin console → **Data** → **Compliance** → **Access Management** shows the required policy on the pilot OU. `GWREG-Validation.ps1` reports the policy vs. required.
- **Pass:** Policy matches the approved requirement; OU is licensed.
- **Fail:** Policy is **No preference**/wrong, or OU is unlicensed (policy silently does not apply) → remediate / fix licensing.

Test 3 — Access Approvals

- **What:** "Require Google staff to request approval before viewing data" is enabled for the pilot OU.
- **How:** Admin console → **Data** → **Compliance** → **Access Approvals** shows the box checked; `GWREG-Validation.ps1` reports enabled.
- **Pass:** Enabled for the pilot scope.
- **Fail:** Unchecked → enable and re-test.

Test 4 — Access Transparency evidence

- **What:** Google-staff access is logged and reviewable.
- **How:** Admin console reporting → **Access Transparency log events** returns events (or is confirmed active). If a support interaction occurred, it appears with the Access-Approvals approval.

• **Pass:** Access Transparency is active and queryable; approvals are visible.

• **Fail:** No access-transparency surface / not queryable → **verify in your tenant** and confirm the add-on entitlement.

Test 5 — Client-Side Encryption (only if relied upon)

• **What:** CSE is enabled for the required services on the controlled OU (if legal relies on the ITAR e2ee carve-out).

• **How:** Admin console → **Data** → **Compliance** → **Client-side encryption**; controlled services show CSE

on for the OU. `GWREG-Validation.ps1` reports CSE state.

• **Pass:** CSE on for the required services/OU, key service connected.

• **Fail / N/A:** If legal does not require CSE, mark **N/A**; if required and off → enable and re-test.

Test 6 — Compliance-evidence exports

• **What:** Policy-compliance log events, data-regions advanced reporting, and compliance data exports are available and routed to the evidence destination (requirement 2.8).

• **How:** Confirm the exports/log events are produced; `GWREG-Report.ps1` compiles the coverage report.

• **Pass:** Evidence is produced and retained per requirement.

• **Fail:** Missing evidence surface → enable the bundled feature (verify entitlement).

Test 7 — Functional / no-regression on the pilot

• **What:** Controlled-data pilot users can still work; cross-region processing changes and CSE have not broken essential workflows.

• **How:** Pilot users confirm Gmail/Drive/Docs/Calendar/Meet function; note any lost functionality from disabling cross-region processing or from CSE.

• **Pass:** Users productive; any tradeoffs are known and accepted by the stakeholders.

• **Fail:** Broken workflow → adjust advanced-settings/CSE scope and re-test.

Test 8 — Coverage & sign-off gate (pilot exit)

• **What:** All required controls pass across the pilot **and** legal/compliance has reviewed the evidence and signed off.

• **How:** `GWREG-Validation.ps1` = all required controls pass; `GWREG-Report.ps1` coverage attached;

legal/compliance sign-off recorded.

- **Pass:** Proceed to Expand (Implementation Step 8).
- **Fail:** Remediate and re-validate; do **not** expand on a technical pass without the legal sign-off.

Pass/fail summary

#	Test	Pass criterion
1	Data-region residency	Region = required target; reporting confirms
2	Access Management	Required policy applied; OU licensed
3	Access Approvals	Enabled for pilot scope
4	Access Transparency	Active, queryable; approvals visible
5	CSE (if relied upon)	On for required services/OU, or N/A
6	Compliance-evidence exports	Produced and retained
7	Functional / no-regression	Pilot users productive; tradeoffs accepted
8	Coverage & sign-off gate	All required pass + legal/compliance sign-off

6. Troubleshooting — Regulated Google Workspace: Assured Controls, ITAR & DFARS

Symptom → likely cause → fix for the common issues configuring controlled-data controls in Google Workspace. Where a cause is edition-/contract-dependent, the fix is to **verify in your tenant** and confirm entitlement — never assume a feature that Google's documentation does not confirm.

Access Management / Access Approvals

Symptom: "Access Management" / "Access Approvals" not visible under Data → Compliance.

- Cause: The **Assured Controls / Assured Controls Plus** add-on is not licensed, or you are not a **super administrator** (Access Management requires super-admin).
- Fix: Confirm the add-on in **Billing → Subscriptions** (requirement 2.1) and sign in as super-admin.

Access Management specifically requires **Assured Controls Plus** (or the legacy Assured Controls SKU Google documents) — **verify which SKU carries it for your contract.**

Symptom: Access-Management policy was saved but appears to have no effect for some users.

- Cause: Policies apply **only to users in OUs that hold the Assured Controls license**; those users' OU is unlicensed, or they are in a child OU that inherited **No preference**.

• Fix: Confirm the OU is licensed; check the OU/child-OU policy (use **Override** on the child OU to set the required policy). Re-run `GWREG-Validation.ps1`.

Symptom: The required policy option (e.g. CJIS / IRS 1075) is not listed.

• Cause: Policy availability is edition-/contract-dependent and evolves.

• Fix: **Verify in your tenant** and confirm entitlement with Google/your reseller — do not substitute a different policy without legal/compliance approval (requirement 2.2).

Data regions / residency

Symptom: Data region set to United States but reporting still shows out-of-region data.

• Cause: Residency migration is on **Google's schedule**, not instantaneous; or the setting was applied to the wrong OU.

• Fix: Confirm the correct OU is set (Data → Compliance → Data regions), allow Google's migration window, and re-check **data-regions advanced reporting**. Escalate to Google support if it does not converge.

Symptom: "Advanced settings" for data regions is unavailable.

• Cause: Advanced (per-OU cross-region-processing) settings require **Frontline Plus / Enterprise Plus or the Data Regions add-on**.

• Fix: Confirm the qualifying edition/add-on (requirement 2.4); **verify in your tenant.**

Symptom: Users lost functionality after disabling cross-region processing.

• Cause: Google warns that disabling features that may process data across regions can remove familiar

functionality.

• Fix: Re-evaluate with the stakeholders which services truly require strict in-region processing; narrow the disablement to the required services and re-test (Testing Test 7).

Client-Side Encryption (CSE)

Symptom: CSE cannot be enabled / content not encrypting.

• Cause: The external **key service / IdP** is not connected, or CSE is not enabled for the service/OU.

• Fix: Confirm the key service under **Data** → **Compliance** → **Client-side encryption** (stand up per Google's CSE docs — deferred to vendor), then enable CSE for the required services/OU.

Symptom: Some features can't open CSE-protected content.

• Cause: Expected — CSE content is indecipherable to Google, so features that must read content are limited.

• Fix: This is a known tradeoff; scope CSE deliberately and document the impact. Do not treat CSE as the

only control — it complements residency and access controls.

Evidence / Access Transparency

Symptom: No Access Transparency log events appear.

• Cause: Access Transparency not active for the account, entitlement not present, or simply no Google-staff access has occurred yet.

• Fix: Confirm **Access Transparency log events** is selectable in reporting; confirm the add-on entitlement (**verify in your tenant**). Absence of events can also mean no access occurred — not a failure.

Symptom: Compliance exports / policy-compliance log events missing.

• Cause: The bundled evidence feature is not enabled, or entitlement is absent.

• Fix: Enable the feature (it ships with the add-on) and confirm entitlement; route output to the evidence destination (requirement 2.8).

Scripts

Symptom: Script returns "Set GOOGLE_OAUTH_TOKEN…" and exits.

• Cause: No OAuth access token in the environment.

• Fix: Set `GOOGLE_OAUTH_TOKEN` to a super-admin token (`gcloud auth print-access-token` or your OAuth flow) with the required scopes named in each script's header.

Symptom: `GWREG-Remediation.ps1` **/** `GWREG-Set-ScopeTargeting.ps1` **"did nothing."**

• Cause: Both **default to** `-WhatIf` — they only preview.

• Fix: Review the preview, get change approval, then re-run with `-Execute` inside the approved window.

Symptom: API 403 / insufficient permission.

• Cause: The token lacks the scope/role for the surface being read or set.

• Fix: Grant the least-privilege scope/role named in the script header; reserve super-admin for Access-Management operations.

Symptom: `GWREG-Validation.ps1` **reports FAIL but the Admin console looks correct.**

• Cause: The validation compares against the **required posture** you supplied; the console value may differ from what legal/compliance approved, or the wrong scope was validated.

• Fix: Confirm the required-posture inputs and the target OU; reconcile with the console value and, if the console is wrong, remediate (Implementation Step 7).

7. Best Practices — Regulated Google Workspace: Assured Controls, ITAR & DFARS (Evidence & Audit)

Practices for running a controlled-data Workspace configuration that is **defensible** — with the evidence and audit trail an assessor expects. The theme throughout: **configure once, name it, apply it by scope, and prove it.** Regulatory **interpretation stays with legal/compliance**; these practices keep the **technical evidence** clean.

Governance & interpretation

- **Keep the interpretation owner explicit.** Every "which region / which policy / is CSE required"

decision is recorded against a named legal/compliance owner and an approval date. The technical team configures to the approved requirement — it does not decide the requirement.

- **Separate "configured" from "compliant."** Your reports state *technical coverage* ("Access

Management = U.S.-only, applied to OU X, licensed"), never "ITAR compliant." Compliance is legal's written determination on top of the evidence.

- **Re-review on regime or contract change.** ITAR/DFARS interpretations, Google SKUs, and

Access-Management policy options evolve — schedule a periodic re-confirmation and flag add-on/edition-gated items as **"verify in your tenant."**

Scope & configuration discipline

- **Name and reuse configurations.** Use stable names — `RES-US-Controlled`, `AXM-US-Controlled` /

`AXM-CJIS-Controlled` — and apply them verbatim across every controlled OU so the fleet is consistent and auditable. Never hand-tune per OU.

- **Right-size the controlled scope.** Apply residency and support-access restrictions to the

controlled-data OUs only (from the data classification, requirement 2.3) — over-broad application is disruptive; too-narrow leaves data exposed.

- **Verify licensing before applying Access Management.** The policy silently does not apply to

unlicensed OUs — confirm Assured Controls licensing on every OU you target.

- **Pilot everything; roll back cleanly.** Prove each control on the pilot OU with a documented rollback

before touching the wider fleet; residency and CSE changes are high-impact.

Evidence & audit

- **Treat Access Transparency as the primary provider-access evidence.** It logs Google-staff access

allowed via Access Management / Access Approvals — route it to your SIEM/evidence store with the retention the regime requires (requirement 2.8).

- **Collect the bundled evidence features.** Enable and retain **policy-compliance log events**,

data-regions advanced reporting, and **compliance data exports** — these are the coverage proof the add-on provides.

- **Snapshot coverage on a cadence.** Run `GWREG-Report.ps1` on a schedule (and before each audit) so

you have a dated coverage/evidence record per controlled OU; keep the history.

- **Validate continuously, not just at go-live.** Re-run `GWREG-Validation.ps1` after any change and on a

cadence to catch drift (an OU added without the policy, a region reverted, a license lapse).

- **Keep change records.** Every residency/access/CSE change ties to a change ticket with approver,

window, and rollback — the audit trail is the ticket **plus** the before/after validation output.

Operational safety

- **Default to read-only / `-WhatIf`.** Discovery, Validation, and Report are read-only; Remediation and

Set-ScopeTargeting default to `-WhatIf` — preview and get approval before executing.

- **Least privilege.** Reserve super-admin for the Access-Management change; use scoped compliance/data

admin roles for Data regions, Access Approvals, and CSE.

- **Protect CSE keys and account for functional tradeoffs.** If CSE is relied upon, key-service

ownership and availability are part of the control — and some features cannot read CSE content, so scope deliberately and document the tradeoffs for users.

- **Never publish secrets in evidence.** Coverage reports record *that* a control is configured and its

scope — never keys, tokens, or credentials.

Anti-patterns to avoid

- Declaring "ITAR/DFARS compliant" from a script pass — that is legal's determination.
- Applying Access Management to an **unlicensed** OU and assuming it took effect.
- Expanding fleet-wide before a pilot pass **and** legal sign-off.
- Disabling cross-region processing or enabling CSE tenant-wide without piloting the functional impact.
- Inventing an Access-Management policy option or Assured Controls feature not in Google's documentation

— cite or flag "verify in your tenant" instead.

8. Deliverables Summary — Regulated Google Workspace: Assured Controls, ITAR & DFARS

Everything included in this solution and how the pieces fit the **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** model. The solution delivers the **technical configuration and evidence** for controlled data; **regulatory interpretation is deferred to legal/compliance**.

Documentation

Doc	Purpose
01 — Solution Overview	How Assured Controls, data regions, and access-management/approval controls map to ITAR/DFARS controlled-data requirements; scope and limits
02 — Requirements Guide	Prerequisites (add-on/edition, legal/compliance stakeholders, data classification, data regions, CSE readiness, admin roles, pilot, evidence destination) — each with Description · Why · Verify · Implement
03 — Implementation Guide	Click-by-click: configure data-region residency, Access Management, Access Approvals, the evidence surface, and (if legal-required) CSE; pilot, validate, remediate, expand
05 — Testing & Validation	Pass/fail tests per control against the required posture, with a pilot-exit sign-off gate
06 — Troubleshooting	Symptom → cause → fix for the common configuration issues
07 — Best Practices	Evidence-and-audit discipline: named configs, scope, Access Transparency, coverage snapshots, safe operations
executive-summary	One-page business framing for compliance/security leadership

Scripts (5)

All PowerShell, driven by a Google super-admin OAuth token (read-only scopes for the read-only scripts). Read-only scripts change nothing; state-changing scripts default to `-WhatIf`.

Script	Role	Safety
GWREG-Discovery.ps1	Controlled-data posture discovery — data region, CSE, Access Management/Approvals state, controlled OU layout	Read-only
GWREG-Validation.ps1	Per-scope validation of each control **against the required posture**, pass/fail	Read-only

Script	Role	Safety
GWREG-Report.ps1	Compliance **coverage / evidence** report across scopes	Read-only
GWREG-Remediation.ps1	Bring a scope to the required posture (region / Access Management / Approvals)	`-WhatIf` **default**
GWREG-Set-ScopeTargeting.ps1	Create/grow the controlled-data pilot OU/group targeting	`-WhatIf` **default**

How they fit the deployment model

- **Assess** — `GWREG-Discovery.ps1` baselines posture; stakeholders confirm the required target.
- **Configure** — Implementation Steps 1–5 (Data regions, Access Management, Access Approvals, evidence, CSE), scoped with `GWREG-Set-ScopeTargeting.ps1`.
- **Pilot / Validate** — `GWREG-Validation.ps1` + `GWREG-Report.ps1`; legal/compliance sign-off gate.
- **Remediate** — `GWREG-Remediation.ps1` (`-WhatIf` → approved execute).
- **Expand** — apply the named configs fleet-wide; re-validate and snapshot coverage.

Outcome

Google Workspace configured for controlled data — **U.S. (or required-region) residency**, **support-access limited by location/eligibility and gated by approval**, an **Access-Transparency evidence trail**, and (where legal relies on it) **CSE** — **proven on a pilot** and **signed off by legal/compliance** before fleet-wide rollout, with named, reusable configurations and a documented rollback. The determination that this satisfies ITAR/DFARS remains **legal/compliance's**, made on the evidence this solution produces.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

GWREG-Discovery.ps1

Purpose: Read-only baseline of the controlled-data posture BEFORE any change. Enumerates organizational units (the controlled-data scope), reports data-region residency where readable, samples Drive for external/broad sharing on controlled OUs, and prints where each compliance control lives in the Admin console (Access Management, Access Approvals, Data regions, Client-side encryption) so the operator can confirm state. Interpretation of what posture is REQUIRED is deferred to legal/compliance — this only reports what IS. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\GWREG-Discovery.ps1 -CustomerId your-customer-id [-MaxFiles 300] Requires a Google super-admin OAuth access token with READ-ONLY scopes: admin.directory.orgunit.readonly, admin.directory.group.readonly, drive.metadata.readonly. Put the token in the GOOGLE_OAUTH_TOKEN environment variable (e.g. 'gcloud auth print-access-token'). Nothing is written. EXPECTED RESULTS A list of OUs, a broad/external Drive-sharing sample, and an Admin-console control-location map with a "verify in your tenant" note for add-on-gated features. Nothing changes. Feed OUs into GWREG-Set-ScopeTargeting.ps1 and controls into GWREG-Validation.ps1 / GWREG-Report.ps1. .NOTES White-label — the repeatable way. Read-only against the Google Directory & Drive APIs. Assured Controls / Access Management state and policy options are add-on-/edition-dependent and are cited or flagged "verify in your tenant"; regulatory interpretation is deferred to legal/compliance. #> [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$CustomerId, [int]$MaxFiles = 300)

How to run: powershell -ExecutionPolicy Bypass -File .\GWREG-Discovery.ps1 -CustomerId your-customer-id [-MaxFiles 300] Requires a Google super-admin OAuth access token with READ-ONLY scopes: admin.directory.orgunit.readonly, admin.directory.group.readonly, drive.metadata.readonly. Put the token in the GOOGLE_OAUTH_TOKEN environment variable (e.g. 'gcloud auth print-access-token'). Nothing is written. EXPECTED RESULTS A list of OUs, a broad/external Drive-sharing sample, and an Admin-console control-location map with a "verify in your tenant" note for add-on-gated features. Nothing changes. Feed OUs into GWREG-Set-ScopeTargeting.ps1 and controls into GWREG-Validation.ps1 / GWREG-Report.ps1. .NOTES White-label — the repeatable way. Read-only against the Google Directory & Drive APIs. Assured Controls / Access Management state and policy options are add-on-/edition-dependent and are cited or flagged "verify in your tenant"; regulatory interpretation is deferred to legal/compliance. #> [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$CustomerId, [int]$MaxFiles = 300)

GWREG-Remediation.ps1

Purpose: Safely brings a target OU to the REQUIRED controlled-data posture that legal/compliance approved: data region (e.g. United States), Access Management policy (e.g. us-only or cjis-irs), and Access Approvals on. It DEFAULTS TO -WhatIf and only PREVIEWS the intended changes; nothing is applied until you pass -Execute inside an approved change window. It does not decide the required posture and never enables CSE automatically (CSE is stood up deliberately per legal - see the guide). HOW TO RUN Preview (default, safe): powershell -ExecutionPolicy Bypass -File .\GWREG-Remediation.ps1 -OrgUnitPath /Controlled ` -RequiredRegion unitedstates -RequiredAccessMgmt us-only -RequireAccessApprovals Apply (only in the approved change window): ... same parameters ... -Execute Requires a SUPER-ADMIN OAuth token in GOOGLE_OAUTH_TOKEN with

the compliance-admin scopes for the surfaces changed (Access Management requires super-admin). Re-validate with GWREG-Validation.ps1. EXPECTED RESULTS In -WhatIf (default): a numbered list of the exact changes that WOULD be made, and no change. With -Execute: each change attempted with a pass/fail line. Some compliance settings are applied in the Admin console when no write API is available - those are emitted as explicit MANUAL steps, never silently skipped. .NOTES White-label — the repeatable way. Default -WhatIf; changes only with -Execute in an approved window. Required posture comes from legal/compliance, not this script. Assured Controls policy options / write surfaces are add-on-gated and cited or flagged "verify in your tenant"; never invents specifics. #> [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$OrgUnitPath, [ValidateSet('nopreference','unitedstates','europe')][string]$RequiredRegion = 'unitedstates', [ValidateSet('no-preference','us-only','cjis-irs','eu-only')][string]$RequiredAccessMgmt = 'us-only', [switch]$RequireAccessApprovals, [switch]$Execute)

How to run: Preview (default, safe): powershell -ExecutionPolicy Bypass -File .\GWREG-Remediation.ps1 -OrgUnitPath /Controlled ` -RequiredRegion unitedstates -RequiredAccessMgmt us-only -RequireAccessApprovals Apply (only in the approved change window): ... same parameters ... -Execute Requires a SUPER-ADMIN OAuth token in GOOGLE_OAUTH_TOKEN with the compliance-admin scopes for the surfaces changed (Access Management requires super-admin). Re-validate with GWREG-Validation.ps1. EXPECTED RESULTS In -WhatIf (default): a numbered list of the exact changes that WOULD be made, and no change. With -Execute: each change attempted with a pass/fail line. Some compliance settings are applied in the Admin console when no write API is available - those are emitted as explicit MANUAL steps, never silently skipped. .NOTES White-label — the repeatable way. Default -WhatIf; changes only with -Execute in an approved window. Required posture comes from legal/compliance, not this script. Assured Controls policy options / write surfaces are add-on-gated and cited or flagged "verify in your tenant"; never invents specifics. #> [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$OrgUnitPath, [ValidateSet('nopreference','unitedstates','europe')][string]$RequiredRegion = 'unitedstates', [ValidateSet('no-preference','us-only','cjis-irs','eu-only')][string]$RequiredAccessMgmt = 'us-only', [switch]$RequireAccessApprovals, [switch]$Execute)

GWREG-Report.ps1

Purpose: Read-only report that compiles the controlled-data control COVERAGE across the scopes you list - data-region residency, Access Management policy, Access Approvals, Access Transparency evidence, and CSE where relied upon - into a dated coverage/evidence record for the audit file. It states TECHNICAL coverage and its scope; it does NOT assert ITAR/DFARS compliance (that is legal's determination on top of this evidence). Exports optional CSV/JSON for attachment to the audit. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\GWREG-Report.ps1 -OrgUnitPaths /Controlled,/Controlled/Eng ` [-OutFile coverage-report] [-CustomerId your-domain-customer-id] Requires a super-admin OAuth token in GOOGLE_OAUTH_TOKEN (read-only). Where a control cannot be read live it is recorded as 'confirm-in-console' so the record is honest. No changes are made. EXPECTED RESULTS A per-scope coverage table on screen and, if -OutFile is set, coverage-report.csv/.json for the evidence store. Run on a cadence and before each audit; keep the dated history (best practice). .NOTES White-label — the repeatable way. Read-only. Reports coverage/evidence, never a legal conclusion. Add-on-gated evidence features (policy-compliance log events, data-regions advanced reporting, compliance exports) are cited or flagged "verify in your tenant"; no secrets are ever recorded. #> [CmdletBinding()] param([Parameter(Mandatory=$true)][string[]]$OrgUnitPaths, [string]$OutFile, [string]$CustomerId)

How to run: powershell -ExecutionPolicy Bypass -File .\GWREG-Report.ps1 -OrgUnitPaths /Controlled,/Controlled/Eng ` [-OutFile coverage-report] [-CustomerId your-domain-customer-id] Requires a super-admin OAuth token in GOOGLE_OAUTH_TOKEN (read-only). Where a control cannot be read live it is recorded as 'confirm-in-console' so the record is honest. No changes are made. EXPECTED RESULTS A per-scope coverage table on screen and, if -OutFile is set, coverage-report.csv/.json for the evidence store. Run on a cadence and before each audit; keep the dated history (best practice). .NOTES White-label — the repeatable way. Read-only. Reports coverage/evidence, never a legal conclusion. Add-on-gated evidence features (policy-compliance log events, data-regions advanced reporting, compliance exports) are cited or flagged "verify in your tenant"; no secrets are ever recorded. #> [CmdletBinding()] param([Parameter(Mandatory=$true)][string[]]$OrgUnitPaths, [string]$OutFile, [string]$CustomerId)

GWREG-Set-ScopeTargeting.ps1

Purpose: Stages the controlled-data SCOPE that every control in this solution targets: creates (or previews) a controlled-data organizational unit and/or a targeting group (e.g. 'Regulated Workspace - Controlled Data - Pilot') and optionally adds representative members, so residency, Access Management, Access Approvals, and CSE are applied consistently and can be expanded verbatim. It DEFAULTS TO -WhatIf and only PREVIEWS; membership/scope changes apply only with -Execute. HOW TO RUN Preview (default, safe): powershell -ExecutionPolicy Bypass -File .\GWREG-Set-ScopeTargeting.ps1 -CustomerId your-customer-id ` -GroupEmail controlled-data-pilot@your-domain -Members alice@your-domain,bob@your-domain Apply (only in the approved change window): ... same parameters ... -Execute Requires a super-admin OAuth token in GOOGLE_OAUTH_TOKEN with admin.directory.group and admin.directory.group.member scopes (and orgunit scope if creating an OU). Nothing changes in -WhatIf. EXPECTED RESULTS In -WhatIf (default): the group/OU and members that WOULD be created/added, and no change. With -Execute: the group is created if absent and members are added, each with a pass/fail line. Use the resulting scope in GWREG-Validation.ps1 / GWREG-Report.ps1 and as the target for the controls. .NOTES White-label — the repeatable way. Default -WhatIf; writes only with -Execute in an approved window. Creates targeting scope only - it applies NO compliance policy itself (that is the guide's steps). Uses the Google Directory API; least-privilege scopes; never invents Assured Controls specifics. #> [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$CustomerId, [Parameter(Mandatory=$true)][string]$GroupEmail, [string]$GroupName = 'Regulated Workspace - Controlled Data - Pilot', [string[]]$Members = @(), [switch]$Execute)

How to run: Preview (default, safe): powershell -ExecutionPolicy Bypass -File .\GWREG-Set-ScopeTargeting.ps1 -CustomerId your-customer-id ` -GroupEmail controlled-data-pilot@your-domain -Members alice@your-domain,bob@your-domain Apply (only in the approved change window): ... same parameters ... -Execute Requires a super-admin OAuth token in GOOGLE_OAUTH_TOKEN with admin.directory.group and admin.directory.group.member scopes (and orgunit scope if creating an OU). Nothing changes in -WhatIf. EXPECTED RESULTS In -WhatIf (default): the group/OU and members that WOULD be created/added, and no change. With -Execute: the group is created if absent and members are added, each with a pass/fail line. Use the resulting scope in GWREG-Validation.ps1 / GWREG-Report.ps1 and as the target for the controls. .NOTES White-label — the repeatable way. Default -WhatIf; writes only with -Execute in an approved window. Creates targeting scope only - it applies NO compliance policy itself (that is the guide's steps). Uses the Google Directory API; least-privilege scopes; never invents Assured Controls specifics. #> [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$CustomerId, [Parameter(Mandatory=$true)][string]$GroupEmail,

[string]$GroupName = 'Regulated Workspace - Controlled Data - Pilot', [string[]]$Members = @(), [switch]$Execute)

GWREG-Validation.ps1

Purpose: Read-only pass/fail validation of each controlled-data control on a target scope (OU) AGAINST the required posture that legal/compliance approved: data region (e.g. United States), Access Management policy (e.g. us-only or cjis-irs), Access Approvals on, and CSE where relied upon. The REQUIRED values are supplied as parameters - the script does not decide them; it only checks the live/observed state matches. Regulatory sufficiency remains a legal/compliance determination. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\GWREG-Validation.ps1 -OrgUnitPath /Controlled `-RequiredRegion unitedstates -RequiredAccessMgmt us-only -RequireAccessApprovals` [-RequireCSE] [-CustomerId your-customer-id] Requires a super-admin OAuth token in GOOGLE_OAUTH_TOKEN with READ-ONLY compliance/reporting scopes for the surfaces you validate. Nothing is written. Where a control cannot be read via API, the check is reported UNVERIFIED (confirm in the Admin console) rather than passed. EXPECTED RESULTS A pass/fail (or UNVERIFIED) line per control for the scope, and an overall gate result. FAIL or UNVERIFIED blocks the pilot-exit gate until remediated (GWREG-Remediation.ps1) or confirmed in the Admin console. Attach the output to the evidence record via GWREG-Report.ps1. .NOTES White-label — the repeatable way. Read-only. Checks OBSERVED state against REQUIRED inputs; does not interpret regulation. Assured Controls policy options / add-on gating are cited or flagged "verify in your tenant"; unread controls are UNVERIFIED, never assumed compliant. #> [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$OrgUnitPath, [ValidateSet('nopreference','unitedstates','europe')][string]$RequiredRegion = 'unitedstates', [ValidateSet('no-preference','us-only','cjis-irs','eu-only')][string]$RequiredAccessMgmt = 'us-only', [switch]$RequireAccessApprovals, [switch]$RequireCSE, [string]$CustomerId)

How to run: powershell -ExecutionPolicy Bypass -File .\GWREG-Validation.ps1 -OrgUnitPath /Controlled `-RequiredRegion unitedstates -RequiredAccessMgmt us-only -RequireAccessApprovals` [-RequireCSE] [-CustomerId your-customer-id] Requires a super-admin OAuth token in GOOGLE_OAUTH_TOKEN with READ-ONLY compliance/reporting scopes for the surfaces you validate. Nothing is written. Where a control cannot be read via API, the check is reported UNVERIFIED (confirm in the Admin console) rather than passed. EXPECTED RESULTS A pass/fail (or UNVERIFIED) line per control for the scope, and an overall gate result. FAIL or UNVERIFIED blocks the pilot-exit gate until remediated (GWREG-Remediation.ps1) or confirmed in the Admin console. Attach the output to the evidence record via GWREG-Report.ps1. .NOTES White-label — the repeatable way. Read-only. Checks OBSERVED state against REQUIRED inputs; does not interpret regulation. Assured Controls policy options / add-on gating are cited or flagged "verify in your tenant"; unread controls are UNVERIFIED, never assumed compliant. #> [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$OrgUnitPath, [ValidateSet('nopreference','unitedstates','europe')][string]$RequiredRegion = 'unitedstates', [ValidateSet('no-preference','us-only','cjis-irs','eu-only')][string]$RequiredAccessMgmt = 'us-only', [switch]$RequireAccessApprovals, [switch]$RequireCSE, [string]$CustomerId)